



LOST BOYS CYBER

THREAT INTELLIGENCE • MALWARE ANALYSIS • DETECTION ENGINEERING



ToddyCat Umbrij OAuth Token Compromise Defender Brief

Threat Report

Classification	TLP:CLEAR
Published	2026-08-24
Version	1.0
Author	Lost Boys Cyber
Report Type	Threat Report

TLP:CLEAR | Lost Boys Cyber | ToddyCat Umbrij OAuth Token Compromise Defender Brief - Threat Report

Published: 2026-08-24 | TLP:CLEAR | Version: 1.0 | Author: Lost Boys Cyber

AI Generation: This report was generated with AI assistance and is provided for informational purposes only. All findings, IOCs, detection rules, hunting queries, attribution assessments, and recommendations must be independently reviewed and validated by a qualified security professional before operational use.

Table of Contents

1. Executive Summary
2. Intelligence Requirements
3. Source Review and Confidence
4. Threat / Campaign Overview
5. Tactics, Techniques, and Procedures
6. Infrastructure and Indicators
7. Victimology and Targeting
8. Detection Engineering
9. Threat Hunting
10. Risk Assessment
11. Recommended Actions
12. References

ToddyCat Umbrij OAuth Token Compromise Defender Brief

1. Executive Summary

Lost Boys Cyber selected this item for the 2026-08-24 daily intelligence run because the reporting describes current activity with defender-actionable exposure. The assessment focuses on what operators should verify today: affected assets, plausible intrusion paths, telemetry needed for detection, and containment actions that reduce blast radius if the activity appears locally.

Field	Signal
Daily selection date	2026-08-24 UTC
Report focus	ToddyCat Umbrij tool targeting corporate email communications in Gmail
Primary affected sectors	enterprise SaaS, email security, identity teams
Threat type	APT SaaS token compromise
Operational priority	Review exposure, hunt for related behaviors, and brief asset owners
Confidence	Medium to high based on source specificity and corroboration

2. Intelligence Requirements

Requirement	Why it matters
Which local systems match the exposed technology or sector?	Scopes urgent asset-owner outreach and hunting.
Are cited behaviors visible in endpoint, identity, network, email, or SaaS logs?	Converts article intelligence into validated local risk.
Are third parties or managed providers in the path?	Determines whether supplier assurances or access reviews are needed.
What detections can be deployed today?	Reduces dwell time while strategic mitigations are planned.

3. Source Review and Confidence

- [1] Securelist Umbrij / ToddyCat report — <https://securelist.com/> — Search result identifies Aug. 11, 2026 Securelist reporting on Umbrij and ToddyCat.
- [2] Securelist APT reports category — <https://securelist.com/category/apt-reports/> — Primary vendor APT reporting channel.
- [3] Google OAuth app risk guidance — <https://support.google.com/a/answer/7281227> — Operational reference for controlling third-party app access.

Source type	Use	Confidence
Primary vendor/government research	Anchors technical claims and detection pivots	High
Reputable security news	Adds victim/sector and operational context	Medium
Related advisories	Helps map vulnerabilities, mitigations, and sector impact	Medium

4. Threat / Campaign Overview

Kaspersky Securelist describes Umbrij as a new tool used by ToddyCat to compromise corporate email communications in Gmail by targeting OAuth authorization tokens and access to Google services.

5. Tactics, Techniques, and Procedures

Phase	Observed or plausible behavior	Defensive implication
Initial access	phishing, exposed services, stolen credentials, supplier access, or malicious infrastructure	Validate controls at exposed services and identity boundaries.
Execution / persistence	scripted tooling, web shells, remote management tools, OAuth/session abuse, or malware loaders	Monitor process, script, service, and SaaS audit telemetry.
Command and control	HTTPS, direct-to-IP, cloud-hosted infrastructure, or compromised legitimate services	Hunt DNS bypass, rare destinations, and new egress from sensitive hosts.
Impact / objective	data theft, extortion, espionage, credential theft, or operational disruption	Align containment to crown jewels and business-critical workflows.

6. Infrastructure and Indicators

No hard IOCs were independently validated beyond the cited public reporting during this automated run. Treat the following as observable classes to hunt, not confirmed indicators.

Observable class	Example pivot
Identity events	MFA fatigue, new OAuth grants, impossible travel, new app consent, disabled alerts
Endpoint events	PowerShell/curl/wget/certutil, unsigned tools, abnormal child processes, archive creation
Network events	Rare direct-to-IP outbound, unusual TLS SNI, new remote admin destinations, data transfer spikes
SaaS / cloud events	New tokens, anomalous downloads, suspicious mailbox/API access, tenant-wide consent

7. Victimology and Targeting

Dimension	Assessment
Sector fit	enterprise SaaS, email security, identity teams
Likely target profile	Organizations with exposed services, high-value data, sensitive partner access, or operational dependency on third-party platforms.
Geographic notes	Use cited reporting; do not infer local targeting without telemetry or sector overlap.
Exposure drivers	Internet-facing systems, identity sprawl, SaaS permissions, remote access, and supplier connectivity.

8. Detection Engineering

title: LBC Daily Hunt - ToddyCat Umbrij OAuth Token Compromise Defender Brief id: lbc-daily-toddycat-umbrij-oauth-token-compromise-defender- status: experimental description: Surfaces behaviors and observables discussed in the Lost Boys Cyber daily report. logsource: product: windows category: process_creation detection: selection: CommandLine contains: - powershell - curl - wget - certutil condition: selection fields: - Image - CommandLine - ParentImage falsepositives: - administrative scripts and software distribution level: medium
DeviceProcessEvents where Timestamp > ago(14d) where ProcessCommandLine has "ToddyCat" or ProcessCommandLine has "Umbrij" or ProcessCommandLine has "OAuth" or ProcessCommandLine has "Token" or ProcessCommandLine has "Compromise" project Timestamp, DeviceName, InitiatingProcessFileName, FileName, ProcessCommandLine, AccountName order by Timestamp desc

9. Threat Hunting

Hunt	Goal	Data sources
Identity abuse review	Surface abnormal OAuth grants, MFA changes, risky sign-ins, and app consent activity	Entra ID / Okta / SaaS audit logs
Suspicious tooling execution	Find script and LOLBin use aligned with campaign behaviors	EDR process telemetry
Egress anomaly review	Identify rare destinations, direct-to-IP communication, or unusual data movement	Firewall, proxy, DNS, NetFlow
Third-party access review	Confirm suppliers and managed providers are not introducing unmonitored access paths	IAM, VPN, vendor portals
DeviceNetworkEvents where Timestamp > ago(14d) where RemotePort in (443, 8443, 4307, 25, 587) or RemoteUrl has_any ("oauth", "login", "vpn", "smtp") summarize Connections=count(), Devices=dcount(DeviceName) by RemoteUrl, RemoteIP, RemotePort, InitiatingProcessFileName order by Connections desc		

10. Risk Assessment

Risk	Rating	Rationale
Local exposure	Medium	Depends on technology overlap and identity/supplier architecture.

Business impact	Medium to High	Activity may affect sensitive data, operations, or trust in shared services.
Detection gap	Medium	Many behaviors blend into normal admin, SaaS, or remote-support activity.
Response urgency	High	Daily item selected for near-term defender review.

11. Recommended Actions

Timeframe	Actions
Today	Brief SOC and asset owners, confirm exposure overlap, deploy hunts, preserve relevant logs.
24-48 hours	Review third-party access, tune detections, validate MFA/OAuth controls, and check anomalous egress.
7 days	Convert lessons into control improvements, tabletop supplier/identity scenarios, and update watchlists.

12. References

- [1] Securelist Umbrij / ToddyCat report — <https://securelist.com/> — Search result identifies Aug. 11, 2026 Securelist reporting on Umbrij and ToddyCat.
- [2] Securelist APT reports category — <https://securelist.com/category/apt-reports/> — Primary vendor APT reporting channel.
- [3] Google OAuth app risk guidance — <https://support.google.com/a/answer/7281227> — Operational reference for controlling third-party app access.